

Non-Executing Security Analysis of AI Model Supply-Chain Artifacts

Provenance, Serialization, Impersonation, and Repository Risk Inspection

CONTRIBUTION

A primarily non-executing model-artifact security scanner combining static code analysis, symbolic and taint-style inspection, binary-format parsing, provenance checks, and fail-loud handling of incomplete analysis before model loading.

METHOD

- 01

Enumerate repository and model artifacts.
- 02

Parse supported serialization/model formats.
- 03

Apply AST, pattern, symbolic, taint-style, metadata, and provenance checks.
- 04

Reject unsafe dynamic-execution paths in the scanner itself.
- 05

Emit findings and fail-loud states for incomplete or unsafe analysis.

BOUNDARIES / LIMITATIONS

- Static analysis cannot prove a model is safe.
- No claim is made that neural weight backdoors are generally detected.
- Fixture-level results do not establish population-level precision or recall.
- Unsupported or incomplete parsing must remain fail-loud rather than silently clean.

CURRENT VERIFIED EVIDENCE

231	Tests passed
1	Tests skipped
6	Additional pytest subtests passed
68.00%	Statement coverage
55%	CI coverage gate

EVIDENCE NOTES

- 231 passed, 1 skipped, 6 subtests passed.
- 68.00% statement coverage; CI gate is 55%.
- Lint/format, type checking, Bandit, pip-audit, CodeQL, Trivy container scanning, unsafe-dynamic-execution rejection, and Docker build jobs succeeded.

REPRODUCE

```
git clone https://github.com/poojakira/hf-model-provenance-scanner.git
cd hf-model-provenance-scanner
git checkout 4501739a724a2a0a7de9173e51af535b192bf0e4
python -m pip install -e ".[dev,service]"
pytest tests/ -q --cov=scanner --cov-report=term
```